

Relatório de Auditoria e Correções — Movia (v2)

Data: 09/07/2026 **Escopo:** monorepo completo (`apps/backend` , `apps/mobile` , `apps/designer` , `packages/*` , `infra/` , `.github/` , `scripts/` , `docs/`) **Este relatório substitui o `relatorio-auditoria.md` e reflete o estado do projeto após as correções aplicadas em 09/07/2026.**

1. Sumário executivo

A auditoria identificou 1 achado de severidade alta, 5 médios e 7 menores em um projeto com higiene de engenharia acima da média. **8 achados foram corrigidos, 1 foi reclassificado como falso positivo e 3 permanecem em aberto por exigirem decisões do proprietário** (não são corrigíveis só com código).

Estado atual (pós-correção)

Verificação	Resultado
Typecheck backend e mobile (<code>tsc --noEmit</code>)	OK 0 erros
Testes backend	OK 121/121 (19 suítes)
Testes mobile	OK 151/151 (13 suítes — suíte quebrada recuperada)
Testes route-engine	OK 14/14
<code>pnpm audit</code> (pnpm 11, config oficial do projeto)	OK 0 pendências (7 CVEs de tooling com risco aceito documentado)
Segredos no git (atual + histórico)	OK nenhum
<code>any</code> / <code>TODO</code> / <code>FIXME</code> no código-fonte	OK zero

2. Visão geral da arquitetura

Componente	Stack
<code>apps/backend</code>	NestJS 11, Prisma 5.22, PostgreSQL, JWT, Winston, Sentry, prom-client — 20 módulos
<code>apps/mobile</code>	Expo 52, React Native 0.76.9, expo-router, Zustand, React Query, SQLite offline — v2.2.0, i18n es/pt/en
<code>apps/designer</code>	Vite + React, Radix/MUI/Tailwind 4 (ferramenta interna)
<code>packages/*</code>	route-engine, geo-engine, shared-data, shared-types, configs
<code>infra/</code>	Terraform (GCP: Cloud Run, Cloud SQL, Artifact Registry, Secret Manager), docker-compose, nginx
CI/CD	GitHub Actions (security-gate, deploy staging via WIF, pages), Husky + commitlint

Volume: ~28 mil linhas de TS/TSX próprias, 408 arquivos versionados, 195 commits.

3. Achados e correções aplicadas

ALTA A1 — Cloud SQL com TLS opcional — **CORRIGIDO**

Problema: `infra/terraform/main.tf` tinha `ssl_mode = "ALLOW_UNENCRYPTED_AND_ENCRYPTED"` (conexões sem TLS aceitas) e `deletion_protection = false`, contradizendo o comentário "sem IP público exposto".

Correção aplicada:

- `ssl_mode = "ENCRYPTED_ONLY"` — TLS obrigatório em qualquer conexão.
- Socket do Cloud SQL Connector montado no Cloud Run (`volumes/cloud_sql_instance` + `volume_mounts` em `/cloudsql`), concretizando a conexão via socket Unix descrita no comentário.
- `deletion_protection = true` (também cobre o B3).
- IP público mantido **sem** `authorized_networks` — não aceita conexão direta, apenas via connector autenticado por IAM.

MÉDIA M1 — `@movia/geo-engine` não declarado no mobile — **CORRIGIDO**

Problema: `LocationFusion.ts` importava `@movia/geo-engine` sem o pacote estar em `apps/mobile/package.json` (funcionava por hoisting); a suíte `LocationFusion.test.ts` não rodava (`Cannot find module`).

Correção aplicada: `"@movia/geo-engine": "workspace:*` adicionado às dependências, `moduleNameMapper` do Jest mapeado para o source do pacote, `pnpm-lock.yaml` atualizado. Suíte recuperada: mobile passou de 146 para **151 testes passando**.

MÉDIA M2 — Vulnerabilidades do `tar` — **FALSO POSITIVO**

Análise corrigida: as 7 CVEs (6 high, 1 moderate) em `tar@6.2.1` via `@expo/cli` são **risco aceito e documentado pelo projeto** em `docs/security/accepted-risk.md`, com pin deliberado (`@expo/cli>tar: ^6.2.1`) e supressão via `auditConfig.ignoreGhsas` no `pnpm-workspace.yaml`. A auditoria original usou pnpm 9, que não lê essa configuração do pnpm 11 — com o pnpm correto (11.10.0, o `packageManager` do projeto), o audit reporta **0 pendências** e o Security Gate do CI passa. **Nenhuma correção era necessária.**

MÉDIA M3 — Rotação de refresh token perdia a `role` — **CORRIGIDO**

Problema: `refreshSession()` reemitia o token sem repassar a `role` — um token `operator/admin` degradava para `anonymous_device` no primeiro refresh; a `role` não era persistida.

Correção aplicada:

- Coluna `role` (default `anonymous_device`) adicionada ao modelo `DeviceSession` no `schema.prisma`.
- Migração criada: `prisma/migrations/20260709000000_add_role_to_device_session/`.
- `auth.service.ts`: `role` persistida na criação da sessão e repassada no refresh.
- Prisma Client regenerado; 121 testes do backend passando.

Observação em aberto (design): continua não existindo fluxo de emissão de tokens `operator/admin` — os endpoints `@Roles(...)` de `network-state` seguem inalcançáveis até esse fluxo ser definido.

MÉDIA M4 — Senha de usuário SQL literal no Terraform — CORRIGIDO

Problema: `google_sql_user.movia` com `password = "managed-via-secret-manager"` (literal era a senha efetiva, gravada no state).

Correção aplicada: variável `db_user_password` com `sensitive = true` e sem default (obrigatória via `TF_VAR_db_user_password` ou `tfvars` fora do git); `staging.tfvars.example` documentado.

MÉDIA M5 — Cloud Run com service account default do Compute — CORRIGIDO

Problema: runtime usava a SA default do Compute Engine (permissões amplas).

Correção aplicada: SA dedicada `movia-backend-runtime` criada no Terraform, com apenas `secretmanager.secretAccessor` e `cloudsql.client`; Cloud Run e IAM bindings apontados para ela.

BAIXA Baixa severidade

#	Achado	Status
B1	Comparação de <code>METRICS_TOKEN</code> não timing-safe	Corrigido — <code>crypto.timingSafeEqual</code> em <code>metrics.controller.ts</code>
B2	Terraform sem backend remoto (state local)	Em aberto — exige criar/escolher bucket GCS
B3	<code>deletion_protection = false</code> no Cloud SQL	Corrigido (junto com A1)
B4	Senha default fraca do Redis no compose	Corrigido — <code>REDIS_PASSWORD</code> obrigatória (: ?); valor dev adicionado ao seu <code>.env</code> local
B5	Header obsoleto <code>X-XSS-Protection</code> e CSP ampla no nginx	Corrigido — header removido, <code>connect-src</code> restrito a <code>'self'</code>
B6	<code>/v1/auth/session</code> aceita qualquer <code>deviceId</code> (spoofing anônimo, mitigado por throttle)	Em aberto — decisão de design (proof-of-possession)
B7	Restrições da chave Google Maps Android	Em aberto — verificar no console GCP (package name + SHA-1 + APIs)

4. Arquivos alterados

Arquivo	Mudança
<code>infra/terraform/main.tf</code>	A1, B3, M4, M5
<code>infra/terraform/variables.tf</code>	M4 (<code>db_user_password</code>)
<code>infra/terraform/environments/staging.tfvars.example</code>	M4 (documentação)
<code>apps/mobile/package.json</code>	M1 (dependência + Jest)
<code>pnpm-lock.yaml</code>	M1 (link do geo-engine)
<code>apps/backend/prisma/schema.prisma</code>	M3 (coluna <code>role</code>)
<code>apps/backend/prisma/migrations/20260709000000_add_role_to_device_session/</code>	M3 (migração)
<code>apps/backend/src/auth/auth.service.ts</code>	M3 (persistência e repasse da role)
<code>apps/backend/src/observability/metrics/metrics.controller.ts</code>	B1 (timing-safe)
<code>docker-compose.yml</code>	B4 (Redis)

Arquivo	Mudança
infra/nginx/default.conf	B5 (headers)

5. Ações pendentes do seu lado

1. `pnpm install` na raiz — cria o link do `@movia/geo-engine` no mobile e regenera o Prisma Client localmente.
 2. `prisma migrate deploy` no banco de staging — aplica a coluna `role`.
 3. `terraform plan` antes do próximo apply — agora exige `TF_VAR_db_user_password`; a troca de SA e o `ENCRYPTED_ONLY` alteram infra real, revise o plan com atenção.
 4. Decidir os itens em aberto: B2 (backend remoto do state), B6 (modelo de identidade) e B7 (restrições da chave Maps no console).
-

6. Pontos fortes do projeto (inalterados)

Nenhum segredo no git (atual e histórico); CORS fail-fast com wildcard proibido em produção; Helmet + HSTS; validação Joi do ambiente e `ValidationPipe` restritivo; refresh tokens hasheados, rotacionados e revogáveis; throttling por rota; purga automática de sessões (retenção/LGPD); tokens do mobile em SecureStore; deploy via Workload Identity Federation sem chaves de longa duração; Dockerfile non-root; documentação de compliance para CL/BR/AR; zero `any`/TODO em ~28 mil linhas.

Relatório v2 gerado em 09/07/2026 após aplicação e verificação das correções (286 testes passando, typecheck limpo, audit sem pendências).